

Lab 13 - Host de salto



Prof. Dr. Luiz F. Freitas-Gutierrez

luiz.gutierrez@ufsm.br

linkedin.com/in/lffreitas-gutierrez



Lattes

ORCID

SciProfiles

Scopus

ResearcherID

substationworm

LFreitasGutierrez

Resumen del problema

- Realiza una evaluación interna de seguridad de red para una organización industrial de fabricación. El punto de acceso inicial es una estación de trabajo (corp-pc1) dentro de la red corporativa IT. El objetivo principal es identificar vulnerabilidades o errores de configuración que permitan a un atacante pivotar desde la red IT hacia los sistemas OT-ICS de la organización. No se han proporcionado diagramas de red, inventarios de activos ni credenciales administrativas.

Tareas

- **1** Verifica la dirección IP asignada a la estación corp-pc1. OTLab13{XXX.XX.X.XX}
- **2** Determina la subred a la que pertenece corp-pc1. OTLab13{XXX.XX.X.X/XX}
- **3** Desde corp-pc1, identifica las direcciones IP y la información del fabricante (MAC OUI) de otros hosts activos dentro de la red corporativa. OTLab13{XXX.XX.X.XX:<Vendor>,XXX.XX.X.XX:<Vendor>,XXX.XX.X.XX:<Vendor>}
- **4** Identifica al menos otra red alcanzable desde corp-pc1 inspeccionando la tabla de rutas del sistema. OTLab13{XXX.XX.XX.X/XXviaXXX.XX.X.XXXdevethX}
- **5** Para la red descubierta en la tarea anterior, realiza un escaneo TCP y identifica puertos abiertos y servicios expuestos. Pista: usa --top-ports 50. Pista: las reglas del firewall pueden restringir el escaneo en algunos hosts. OTLab13{XXX.XX.XX.XX:<Port>:<Service>}
- **6** Usando los resultados de la tarea anterior, obtén acceso al host de salto y localiza la bandera oculta dentro de sus directorios. OTLab13{Xxxx_Xx_Xxx_Xxxxx}
- **7** Realiza un ping sweep con nmap para identificar hosts OT-ICS disponibles en la red industrial. Reporta sus direcciones IP y la información del fabricante. OTLab13{XXX.XX.XX.XX:<Vendor>,XXX.XX.XX.XX:<Vendor>,XXX.XX.XX.XX:<Vendor>}
- **8** Para el dispositivo OT-ICS cuya dirección IP tiene dos dígitos iguales en el último octeto, identifica el protocolo industrial en uso y extrae el número de serie del dispositivo. OTLab13{XXXxxx,<Serial>}
- **9** Otro host en la red industrial expone una interfaz de administración web. Explora la interfaz y recupera la bandera protegida. OTLab13{Xxxxxxxx_Xxxxxxxx}
- **10** Un mensaje sospechoso se transmite en la red industrial indicando un problema operativo. Intercepta el mensaje e identifica remitente, destinatario y contenido. OTLab13{<Sender_IP>:<Recipient_IP>:XXXXXXXXXXXX_Xxxxx_Xxx}
- **11** En la DMZ, se transmitió un mensaje de estado operativo y quedó almacenado como registro. Localiza el registro e identifica el remitente y el contenido del mensaje. OTLab13{<Sender_IP>:Xxx_Xxx_Xxxxxx_X_Xx_Xxxxxx}

Nota: Algunos dispositivos OT-ICS se basan en Conpot, que reasigna puertos estándar de protocolos y servicios a puertos no privilegiados. Consulta el enlace para ver una lista de algunos puertos estándar y reasignados.

Herramientas

- Las siguientes herramientas se recomiendan para completar OTLab 13: curl, ifconfig, ip, netdiscover, nmap, ssh y tcpdump.

Nomenclatura

- DMZ: zona desmilitarizada.
- ICS: sistema de control industrial.
- IP: protocolo de Internet.
- IT: tecnología de la información.
- MAC: control de acceso al medio.
- OT: tecnología operativa.
- OUI: identificador único organizacional.
- SSH: shell segura.